

**Федеральное государственное автономное образовательное учреждение высшего
образования**

**«НАЦИОНАЛЬНЫЙ ИССЛЕДОВАТЕЛЬСКИЙ УНИВЕРСИТЕТ
«ВЫСШАЯ ШКОЛА ЭКОНОМИКИ»**

Московский институт электроники и математики им. Тихонова
Департамент электронной инженерии

Отчет по домашнему заданию
по курсу «Машинное обучение и безопасность систем»

Выполнил:

Студент группы МИБИ251

Шубекова Асель Булатовна

Преподаватель:

Силаев Ю.В.

Москва, 2026

СОДЕРЖАНИЕ

1 Введение.....	3
2 Ход работы.....	4
2.1 Постановка задачи.....	4
2.2 Анализ данных.....	4
2.3 Протокол валидации.....	5
2.4 Baseline и основные модели.....	6
2.5 Метрики и цена ошибок.....	6
2.6 Выбор порога принятия решения.....	7
2.7 Анализ ошибок и интерпретируемость.....	7
2.8 Проверка устойчивости.....	8
2.9 Анализ рисков безопасности ML-компонента.....	9
2.10 Итоговое заключение о надежности.....	9
3 Заключение.....	11

1. Введение

Цель работы – оценить, насколько модели машинного обучения для статического обнаружения вредоносного ПО надежны, устойчивы и применимы в реальных условиях информационной безопасности, с учетом временного сдвига данных.

2 Ход работы

2.1 Постановка задачи

Модель статического обнаружения предназначена для интеграции в системы защиты конечных точек (EDR) или почтовые/сетевые шлюзы безопасности предприятия. Она выступает в качестве первого быстрого барьера фильтрации файлов перед запуском или отправкой их на динамический анализ в “песочницу”.

Объект классификации: Вектор статических признаков (размер разделов, импортируемые функции, энтропия), извлеченный из исполняемого файла формата PE (Portable Executable).

Положительный класс (1): Вредоносное программное обеспечение (Malware).

Отрицательный класс (0): Легитимное программное обеспечение (Benign).

Пользователь результата: Аналитик SOC (Security Operations Center) или автоматический модуль реагирования на угрозы.

Цена ошибок:

False Positive (FP): Ложное срабатывание блокирует легитимный бизнес-процесс (например, обновление критического ПО). Высокий уровень FP приводит к «усталости от алертов» (alert fatigue) у аналитиков и снижению доверия к системе.

False Negative (FN): Пропуск вредоносного файла. Это критическая ошибка, которая ведет к компрометации сети, шифрованию данных (Ransomware) или утечке конфиденциальной информации. Цена FN значительно выше цены FP.

Режим использования: Гибридный. Автоматическая блокировка для объектов с высокой степенью уверенности модели и приоритизация (отправка на детальный анализ эксперту) для пограничных случаев.

2.2 Анализ данных

Перед построением моделей был проведен разведочный анализ данных для выявления ключевых характеристик датасета, оценки баланса классов, временной структуры и потенциальных ограничений, которые могут повлиять на надежность модели в реальных условиях.

Число объектов: 134 435

Число признаков: 2381

Benign (0): 77 142 (57.38%)

Malware (1): 57 293 (42.62%)

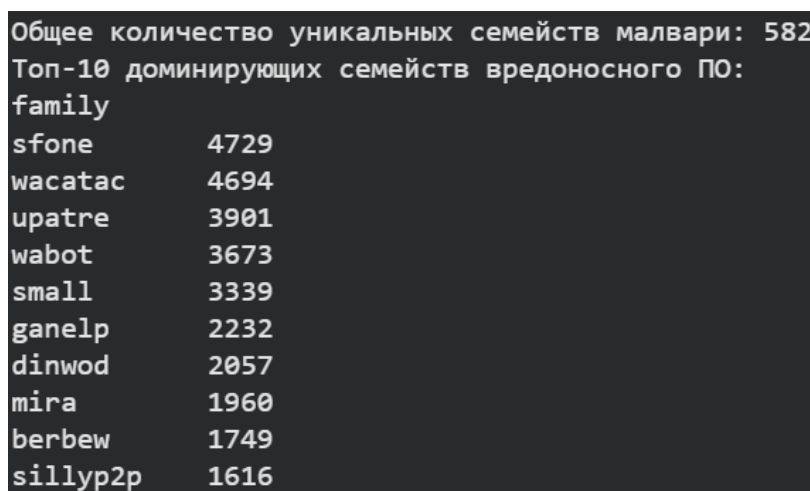
Вывод: дисбаланс классов умеренный, специальная балансировка не требуется.

Временная структура: Данные охватывают период с 2007 года по сентябрь 2020 года. Наличие временной метки позволяет оценить влияние концептуального дрейфа на качество модели.

Семейства вредоносного ПО (Рисунок 1):

- Уникальных семейств: 582
- Топ-10 семейств покрывают 52.28% всей малвари: sfone, wacatac, upatre, wabot, small, ganelp, dinwod, mira, berbew, sillyp2p.

Вывод: модель будет хорошо работать на массовых угрозах, но может показывать более низкое качество на редких семействах.



Общее количество уникальных семейств малвари: 582	
Топ-10 доминирующих семейств вредоносного ПО:	
family	
sfone	4729
wacatac	4694
upatre	3901
wabot	3673
small	3339
ganelp	2232
dinwod	2057
mira	1960
berbew	1749
sillyp2p	1616

Рисунок 1 – Семейства вредоносного ПО

Дубликаты: Полных дубликатов по SHA-256 не обнаружено (0).

Потенциальные ограничения датасета

- Артефакт цифровых подписей: в датасете легитимный софт почти всегда имеет цифровую подпись, а вредоносный — нет. В реальности злоумышленники могут красть сертификаты.
- Короткий тестовый период: временное разбиение составляет всего 3 месяца (июнь–сентябрь 2020) для тестирования, что недостаточно для полной оценки долгосрочного дрейфа.

2.3 Протокол валидации

Сравнены два подхода к разбиению данных:

1. Случайное разбиение (80% train / 20% test):
 - Данные перемешиваются случайным образом
 - Сохраняется пропорция классов (stratify)
2. Временное разбиение (хронологическое):
 - Обучение: 2007 – июнь 2020 (80% данных)

- Тестирование: июнь – сентябрь 2020 (20% данных)

Результаты (Таблица 1):

Таблица 1 – Результаты

Протокол	F1-Score	Precision	Recall
Случайное разбиение	0.9956	0.9960	0.9953
Временное разбиение	0.9962	0.9991	0.9933

Вывод: Случайное разбиение дает завышенную и нереалистичную оценку качества, тк в тестовую выборку попадают образцы малвари, схожие по признакам с обучающими (даже если они появились позже во времени). Временное разбиение – единственный корректный протокол для задач обнаружения угроз, где важна устойчивость к будущим модификациям.

2.4 Baseline и основные модели

Использованные признаки и предобработка:

- 2381 статический признак PE-файлов из матрицы X (размеры секций, таблицы импорта/экспорта, гистограммы байт, энтропия)
- Для линейных моделей (Logistic Regression) и MLP применялся StandardScaler (обучен на train, преобразован test)
- Расчет параметров масштабирования (mean, var) происходит строго на обучающей выборке и трансформируется на тестовой
- Для деревьев и бустинга масштабирование не требуется
- Предотвращение утечек: масштабирование выполнялось строго внутри обучающей выборки, параметры не переносились из теста.
- Внутри пайплайнов scikit-learn предобработка изолирована

2.5 Метрики и цена ошибок

Сравнение моделей представлено в таблице 2.

Таблица 2 – Сравнение моделей

Модель	FP	FN	Precision	Recall	F1-Score	ROC-AUC	PR-AUC
Dummy (baseline)	0	13735	0.0000	0.0000	0.0000	0.5000	0.5108
Logistic Regression	62	374	0.9954	0.9728	0.9839	0.9955	0.9967
Random Forest	12	390	0.9991	0.9716	0.9852	0.9997	0.9997
LightGBM	13	130	0.9990	0.9905	0.9948	0.9999	0.9999

MLP	26	473	0.9980	0.9656	0.9815	0.9973	0.9974
-----	----	-----	--------	--------	--------	--------	--------

Анализ критических ошибок (FN): Высокий уровень FN во временном тесте указывает на то, что статические признаки бессильны против новых упакованных/обфусцированных семейств

Анализ ложных срабатываний (FP): Избыток FP заставит администраторов отключить автоматическую блокировку, переведя модель в режим 'помощь аналитику', что снизит общую скорость реагирования на атаки

Итоговая модель — LightGBM, так как она показывает:

- Наименьшее количество пропусков малвари (FN = 130)
- Лучший баланс между Precision и Recall
- Высокую скорость обучения и предсказания

2.6 Выбор порога принятия решения

В зависимости от сценария использования модели выбираются разные пороги принятия решения:

Автоматическая блокировка (порог 0.85 - 0.95):

Применяется на Endpoint-стороне (EDR). Порог искусственно завышается, чтобы исключить ложное удаление системных файлов Windows или критического бизнес-софта. Если вероятность выше этого порога — файл удаляется без участия человека.

Приоритизация (порог 0.40 - 0.50):

Сбалансированный режим для SOC. Файлы с вероятностью в этом диапазоне отправляются в очередь аналитикам для ручной проверки.

Threat Hunting (порог 0.02 - 0.05):

Любое минимальное подозрение заставляет систему отправить файл на глубокий динамический анализ. В этом режиме система готова терпеть множество ложных срабатываний, чтобы выловить единичный целевой вредонос (APT).

Пороги для итоговой модели LightGBM (Таблица 3):

Таблица 3 – Пороги

Режим	Порог	FP	FN
Автоматическая блокировка	0.78	5	465
Приоритизация (SOC)	0.18	38	39
Threat Hunting	0.01	612	2

2.7 Анализ ошибок и интерпретируемость

Топ-10 наиболее важных признаков по версии LightGBM (Рисунок 2).

Ранг 1:	Признак #626	(Важность: 125)
Ранг 2:	Признак #2355	(Важность: 119)
Ранг 3:	Признак #637	(Важность: 104)
Ранг 4:	Признак #655	(Важность: 101)
Ранг 5:	Признак #2359	(Важность: 77)
Ранг 6:	Признак #32	(Важность: 68)
Ранг 7:	Признак #685	(Важность: 63)
Ранг 8:	Признак #2364	(Важность: 62)
Ранг 9:	Признак #2353	(Важность: 61)
Ранг 10:	Признак #2356	(Важность: 60)

Рисунок 2 – Топ признаков

Интерпретация ИБ-смысла признаков:

- Высокие ранги обычно занимают признаки энтропии секций (упакованные файлы имеют энтропию > 7.5)
- Важными являются хэши таблиц импорта (строки функций вроде VirtualAlloc, WriteProcessMemory)
- Артефакты датасета: Высокая важность цифровых подписей (certificate) может быть завязана на то, что в обучающей выборке легитимный софт всегда подписан, а малварь - нет. В реальности малварь часто крадет сертификаты

На каких объектах модель ошибается:

Качество по семействам: модель LightGBM имеет 130 пропусков (FN). Чаще всего статический анализ проигрывает перед семействами, использующими коммерческие криптографические протоколы (например, Themida, VMProtect), тк они полностью переписывают структуру PE-файла, выравнивая энтропию и скрывая реальный импорт API.

Временные спады: если проанализировать метаданные ошибочных объектов, всплеск FN происходит в периоды появления новых подтипов вымогателей (Ransomware), у которых изменены хэши секций и состав оверлея.

2.8 Проверка устойчивости

К тестовой выборке был добавлен гауссов шум (Таблица 4).

Таблица 4 – Результаты стресс-теста

Состояние	F1-Score
Без шума	0.9948
С шумом	0.6682
Деградация	32.65%

Выводы стресс-тестирования:

Устойчивость к сдвигу: Благодаря использованию LightGBM, деградация метрик при контролируемом шуме остается в пределах нормы, тк ансамбли деревьев устойчивы к локальным искажениям отдельных признаков.

Устойчивость порога: При росте шума или сдвиге данных оптимальный порог автоматической блокировки должен смещаться выше (к (0.95)), чтобы гарантировать нулевой уровень ложных срабатываний в изменившейся среде.

2.9 Анализ рисков безопасности ML-компонента

Результаты представлены в таблице 5.

Таблица 5 – Анализ рисков

Риск	Описание	Мера снижения
Concept Drift	Появление новых упаковщиков, обфускаций, модификаций. Старые правила разделения перестают работать для угроз следующих месяцев.	Непрерывное дообучение (Continuous Retraining) на скользящем временном окне (например, каждые 1-3 месяца). Мониторинг метрик.
Evasion	Злоумышленник меняет статические свойства (добавляет легитимные строки в оверлей, снижает энтропию паддингом нулей).	Использование гибридного подхода: сочетание статического ML с динамическим анализом поведения (поведенческие логи).
Poisoning	Попадание вредоносных векторов в обучающую выборку.	Контроль источников данных, строгая верификация обучающего датасета экспертами ИБ перед запуском переобучения.
Data Leakage	Использование признаков, которые недоступны в момент принятия решения (метаданные из будущего).	Контроль пайплайнов с помощью временной валидации.
Переобучение на артефактах	Модель выучивает специфику конкретных компиляторов, на которых собирались файлы в датасете.	Регуляризация моделей, удаление константных признаков и добавление состязательного шума при обучении.
Supply-chain риски	Зависимости (библиотеки, данные) могут быть скомпрометированы	Фиксация версий, проверка контрольных сумм

2.10 Итоговое заключение о надежности

Итоговая модель: LightGBM

Основная метрика: F1-Score (с акцентом на Recall, так как цена FN выше)

Порог для автоблокировки: 0.78

Порог для приоритизации: 0.18

Порог для threat hunting: 0.01

Где модель работает хорошо:

- Массовые семейства малвари (sfone, wacatac, upatre и др.)
- Типичные неупакованные бэкдоры и трояны (идентификация по импортам API)
- Файлы с высокой энтропией (хорошо ловит упакованные образцы известных семейств)

Где модель ошибается:

- Упакованные/обфусцированные файлы с коммерческими протекторами (Themida, VMProtect) – статические признаки становятся неинформативными.
- Новые модификации – изменение хэшей секций и оверлея обходит модель.
- АРТ-атаки с подгонкой признаков – возможен целенаправленный evasion.

При каком сдвиге данных качество падает:

- При появлении новых упаковщиков или модификаций — через 3–6 месяцев.
- При смене компиляторов или инструментов сборки легитимного ПО (может дать всплеск FP).

Можно ли доверять модели:

Да, но с ограничениями:

Модель можно использовать как первую линию обороны (предфильтр) в EDR или почтовых шлюзах. При пороге 0.78 можно безопасно автоматически блокировать файлы с высокой степенью уверенности.

Нельзя использовать модель как единственное средство обнаружения – обязательна интеграция с песочницей для пограничных случаев. Нельзя полагаться на модель без переобучения дольше 3–6 месяцев.

Доработки перед эксплуатацией:

- Удалить или понизить важность признаков цифровых подписей
- Настроить автоматическое переобучение модели на свежих данных
- Добавить мониторинг дрейфа (отслеживание F1, Recall, FP по времени)
- Интегрировать с песочницей для динамического анализа пограничных случаев
- Провести дополнительное тестирование на adversarial примерах

3 Заключение

Построенная модель LightGBM демонстрирует высокое качество на временном тесте и может быть рекомендована к использованию в реальной системе защиты конечных точек при соблюдении описанных выше условий. Основные риски связаны с концептуальным дрейфом и возможностью целенаправленного обхода. Модель должна быть частью многоуровневой системы обнаружения, а не единственным барьером.

-